SPTI

Arquitectura segura vs Arquitectura insegura

Seminario

2026









Panorama actual



El problema actual de seguridad

- Las aplicaciones modernas están distribuidas en:
  - microservicios
  - cloud
  - aplicaciones móviles
  - APIs

Esto genera una superficie de ataque mayor.

Además:

- Más del 50% de usuarios reutiliza contraseñas.
- El credential stuffing es uno de los ataques más comunes.
- Muchas aplicaciones no detectan intrusiones porque no tienen observabilidad.

Que es la arquitectura insegura?

Contraseñas tradicionales

Seguridad post diseño

Sin trazabilidad

Esto permite ataques como:

- Phishing
- Credential stuffing
- Robo de sesiones
- Escalamiento de privilegios



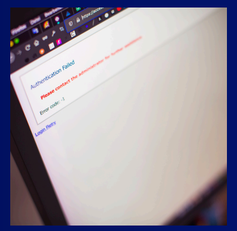
Ejemplos de arquitectura insegura

Problemas principales:

- Contraseñas almacenadas en servidor
- Tokens guardados en localStorage
- Falta de monitoreo de seguridad
- Sin trazabilidad de sesiones



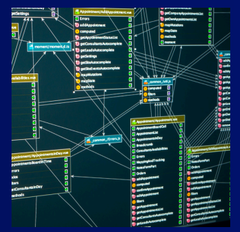
Usuario



Frontend Web



Backend



Base de datos

Vulnerabilidades de Arquitecturas Inseguras

Problemas:

- Phishing
- Reutilización de contraseñas
- Credential stuffing

El monitoreo tradicional solo mide:

- CPU
- memoria
- latencia

Pero no detecta comportamiento malicioso.

Sin logs ni trazas:

- no se puede reconstruir un ataque
- no hay evidencia forense
- no se sabe qué usuario hizo qué acción.

Dependencia de contraseñas

Falta de observabilidad

Falta de trazabilidad

Que es la arquitectura insegura?

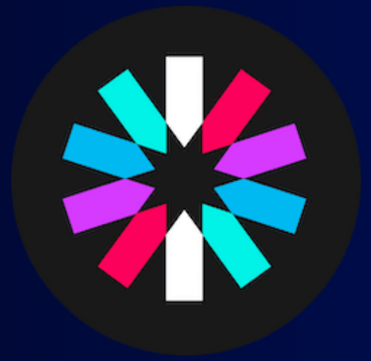
"Nunca confiar, siempre verificar"

Cada solicitud debe:

- autenticarse
- autorizarse
- validarse

Incluso dentro de la red interna.









Componentes de la Arquitectura Segura

La arquitectura propuesta incluye:

1. Passkeys (FIDO2 / WebAuthn)
2. OAuth 2.0 con PKCE
3. JWT para autorización
4. Observabilidad con OpenTelemetry
5. Análisis en Grafana

Esto crea una arquitectura con defensa en profundidad.

Autenticación Segura: Passkeys

Las passkeys eliminan las contraseñas.

Funcionamiento

1. El dispositivo genera un par de claves
2. La clave privada queda en el dispositivo
3. El servidor almacena solo la clave pública

Login

- el servidor envía un challenge
- el dispositivo lo firma
- el servidor verifica la firma.

Ventajas

- imposible hacer phishing
- no hay contraseñas robables.



Recoleccion de una traza de todo el sistema

Esto permite detectar anomalías y ataques.

Patrones numericos

Deteccion de:

- aumento de intentos de login
- caída de tasa de éxito
- patrones de IP sospechosos

Observabilidad: clave de la seguridad moderna

La observabilidad permite entender qué ocurre dentro del sistema.

Se basa en el modelo MELT:

- Metrics
- Events
- Logs
- Traces

Las trazas distribuidas permiten seguir una solicitud a través de todos los servicios.

Beneficios de la Arquitectura Segura

- Elimina el phishing
- Reduce robo de credenciales
- Detecta intrusiones
- Mejora la auditoría
- Cumple estándares de seguridad

OWASP Top 10

NIST SP 800-63

Normativas de protección de datos.

Conclusion

Las arquitecturas tradicionales basadas en contraseñas ya no son suficientes.

La combinación de FIDO2 + OAuth + OpenTelemetry permite construir sistemas seguros, escalables y detectables ante ataques.



Gracias por su atencion



